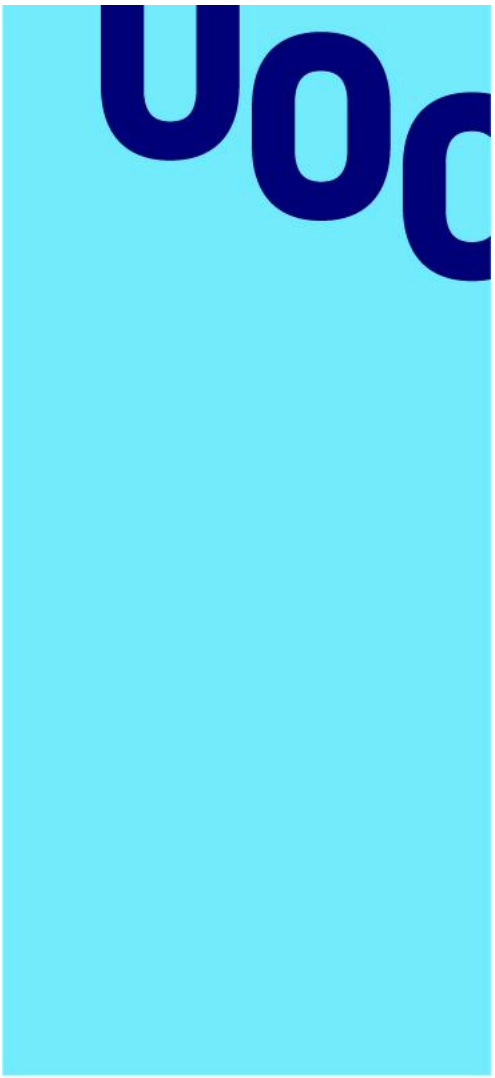
Milenka Ivanovic Marredo

Legislación y protección de datos

PEC-1



Universitat Oberta de Catalunya

Índice

- 1ª PARTE. TEST
- 2ª PARTE. SUPUESTOS PRÁCTICOS
- 3ª PARTE. SUPUESTOS PRÁCTICOS. VERDADERO/FALSO

1ª PARTE. TEST (2 puntos de la PEC)

1) Una clínica privada de fisioterapia Deportiva solicita a sus pacientes, para gestionar las citas médicas, los siguientes datos: nombre, teléfono, correo electrónico, dirección postal, profesión, estado civil, unidad familiar y afición deportiva. La clínica sostiene que todos ellos pueden ser útiles para "conocer mejor al paciente". ¿Crees que esta actuación puede comprometer algún principio del RGPD?

La respuesta correcta es la descrita en la letra: C

Justificad vuestra respuesta (utilizad entre 50 y 200 palabras aproximadamente):

El principio de minimización de datos (artículo 5.1.c del RGPD) establece que los datos personales deben ser adecuados, pertinentes y limitados a lo necesario en relación con los fines para los que son tratado.

La opción C es la correcta porque la finalidad declarada por la clínica es exclusivamente la gestión de citas médicas. Solicitar datos como la profesión, el estado civil, la unidad familiar o las aficiones deportivas resulta excesivo y desproporcionado para agendar una cita. La justificación del responsable de que sirven para "conocer mejor al paciente" no valida legalmente su recopilación.

Las opciones A y D son incorrectas porque, aunque se garantice la exactitud o la confidencialidad, el incumplimiento del principio de minimización vicia de ilicitud el tratamiento. Por su parte, la opción B es incorrecta porque la vulneración objetiva radica en la recopilación masiva e innecesaria de información en el momento del registro, y no en el tiempo durante el cual se conservan los datos.

2) María solicita a una empresa que le confirme si está tratando datos personales sobre ella y, en caso afirmativo, que le facilite una copia de los datos y determinada información sobre el tratamiento. La empresa responde negativamente a dicha petición. ¿Ha operado bien la empresa?

La respuesta correcta es la descrita en la letra: D

Justificad vuestra respuesta (utilizad entre 50 y 200 palabras aproximadamente):

El derecho de acceso se regula en el artículo 15 del RGPD y el artículo 13 de la LOPDGDD. Este derecho habilita a cualquier persona física (el interesado) a obtener directamente del responsable del tratamiento la confirmación de si se tratan sus datos personales y, en su caso, acceder a los mismos y a la información relativa al tratamiento (fines, categorías de datos, destinatarios, etc).

La opción D es la correcta porque María puede ejercitar este derecho de forma personalísima y directa ante el responsable del tratamiento, sin requerir autorización ni cauce judicial alguno. La negativa infundada de la empresa vulnera la normativa.

La opción A es incorrecta dado que el RGPD no exige en ningún caso canalizar las solicitudes de derechos mediante procedimiento judicial. La opción B es incorrecta porque el derecho de acceso ampara a cualquier titular de los datos,

exista o no una relación contractual o la condición de cliente. Finalmente, la opción C es incorrecta ya que este derecho resulta plenamente aplicable con independencia de la base legal que legitime el tratamiento (art. 6 RGPD), sin quedar supeditado a que exista un consentimiento previo.

3) Una empresa recopila información sobre las enfermedades de sus trabajadores para elaborar estadísticas internas de los motivos de las bajas por enfermedad. El director sostiene que, al utilizar los datos con finalidad estadística, estos carecen de consideración sensible, por lo que deja de ser información especialmente protegida. ¿Está en lo cierto?

La respuesta correcta es la descrita en la letra: B

Justificad vuestra respuesta (utilizad entre 50 y 200 palabras aproximadamente):

Los datos sobre las enfermedades de los empleados son considerados categorías especiales de datos conforme al artículo 9.1 del RGPD y la LOPDGDD. La postura del director es totalmente errónea, ya que la finalidad o el destino estadístico interno no despoja a estos datos de su carácter sensible ni exime a la entidad del cumplimiento del régimen de protección reforzada previsto por la legislación vigente.

La opción B es la correcta porque el tratamiento de datos relativos a la salud está sujeto a la prohibición general del artículo 9.1 del RGPD, de modo que solo resulta legítimo si concurre alguna de las excepciones expresas enumeradas en el artículo 9.2 de dicha norma o si se lleva a cabo una anonimización previa e irreversible que impida la identificación de los trabajadores.

La opción A es incorrecta dado que la finalidad estadística perseguida no altera la naturaleza objetiva del dato de salud. La opción C es incorrecta porque la calificación de categoría especial obedece al contenido y sustancia de la información, no al soporte donde conste, como una historia clínica. Por último, la opción D es incorrecta porque el RGPD no prohíbe de forma absoluta tratar datos de salud, siendo posible su tratamiento cuando concurre una causa legitimadora de las previstas en el artículo 9.2 del RGPD, como las obligaciones en materia laboral.

4) Una universidad contrata a una empresa informática para alojar sus bases de datos de estudiantes. La universidad determina para qué finalidades se utilizan los datos y la empresa únicamente los trata para prestar el servicio contratado. ¿Cuál es la posición jurídica de la empresa informática?

La respuesta correcta es la descrita en la letra: C

Justificad vuestra respuesta (utilizad entre 50 y 200 palabras aproximadamente):

La figura del encargado del tratamiento se contempla en el artículo 4.8 y se regula expresamente en el artículo 28 del RGPD, así como en el artículo 33 de la LOPDGDD. Se define como la persona física o jurídica que trata datos personales por cuenta del responsable del tratamiento.

La opción C es la correcta porque la universidad actúa como responsable del tratamiento al determinar los fines y medios del mismo, mientras que la empresa informática asume la condición de encargada del tratamiento al limitar su actuación al alojamiento y prestación del servicio encomendado, siguiendo las instrucciones contractuales de la universidad.

Las opciones A y B son incorrectas porque la empresa no decide la finalidad de los datos ni determina conjuntamente con la universidad los objetivos del tratamiento (art. 26 RGPD). La opción D es incorrecta porque la entidad no es ajena al tratamiento, sino un prestador de servicios legítimamente legitimado e integrado en la operativa mediante el correspondiente contrato de encargo.

5) Una empresa conserva durante treinta años todos los datos de antiguos clientes, alegando que podrían resultar útiles para gestionar asuntos relacionados con los servicios prestados, aunque ya no mantiene ninguna relación contractual con ellos. ¿Está obrando bien?

La respuesta correcta es la descrita en la letra: C

Justificad vuestra respuesta (utilizad entre 50 y 200 palabras aproximadamente):

El principio de limitación del plazo de conservación (artículo 5.1.e del RGPD y artículo 8 de la LOPDGDD) exige que los datos personales se mantengan solo durante el tiempo necesario para cumplir los fines para los que son tratados. Finalizada la relación contractual, los datos deben bloquearse conforme al artículo 32 de la LOPDGDD para atender posibles responsabilidades legales durante sus plazos de prescripción, tras lo cual deben destruirse.

La actuación de la empresa no es correcta porque conservar los datos de antiguos clientes durante treinta años basándose en una mera expectativa de utilidad futura es desproporcionado e ilícito. La mera posibilidad abstracta de gestionar eventuales asuntos no justifica mantener información personal de forma indefinida.

Por tanto, no es admisible retener los datos una vez extinguidas las obligaciones legales contractuales, fiscales o civiles aplicables. La conservación masiva por si acaso vulnera directamente las garantías de protección de datos e invalida la licitud de su almacenamiento continuado.

6) Una organización elabora su registro de actividades de tratamiento, en la que únicamente incluye el nombre del tratamiento y el número de personas afectadas. ¿Está operando correctamente?

La respuesta correcta es la descrita en la letra: D

Justificad vuestra respuesta (utilizad entre 50 y 200 palabras aproximadamente):

El registro de actividades de tratamiento se regula en el artículo 30 del RGPD y el artículo 31 de la LOPDGDD. La normativa exige que dicho registro contenga una serie de contenidos mínimos obligatorios relativos a la operativa del tratamiento, superando el mero listado de nombres o volúmenes de datos.

La opción D es la correcta porque el artículo 30.1 del RGPD establece expresamente que el registro debe incluir, entre otros elementos, los datos de contacto del responsable, las finalidades del tratamiento, la descripción de las categorías de interesados y de datos personales, los destinatarios y los plazos previstos para el supresión. Por tanto, un registro que solo contenga el nombre y el número de afectados es manifiestamente insuficiente.

La opción A es incorrecta porque la excepción por número de empleados (250 trabajadores) exime de la obligación de disponer del registro en ciertos casos, pero no valida confeccionarlo de forma incompleta. La opción B es incorrecta dado que las medidas de seguridad son solo uno de los aspectos a reflejar. La opción C es incorrecta porque el RGPD no eliminó el deber documental, sino que sustituyó la inscripción pública ante la AEPD por este registro interno.

7) Una empresa detecta una brecha de seguridad que puede entrañar riesgo para los derechos y libertades de los afectados. El responsable decide esperar quince días antes de informar a la autoridad de control para comprobar si realmente se han producido daños. ¿Cuál es la respuesta correcta?

La respuesta correcta es la descrita en la letra: B

Justificad vuestra respuesta (utilizad entre 50 y 200 palabras aproximadamente):

La notificación de violaciones de la seguridad de los datos a la autoridad de control está regulada en el artículo 33 del RGPD. La norma impone al responsable la obligación de notificar la brecha sin dilación indebida y, a más tardar, dentro de las 72 horas siguientes a que haya tenido constancia de ella, siempre que constituya un riesgo para los derechos y libertades de las personas físicas.

La opción B es la correcta porque fija el plazo legalmente establecido para la notificación. Esperar quince días para verificar si se han materializado daños efectivos contraviene la exigencia de celeridad que contempla el RGPD para mitigar los posibles perjuicios.

Las opciones A y C son incorrectas porque la obligación de notificar nace del riesgo potencial objetivo derivado de la brecha y no exige la concurrencia de daños efectivos comprobados ni la petición previa del interesado. Finalmente, la opción D es incorrecta dado que las brechas accidentales o de origen fortuito también están sujetas a esta obligación de notificación si generan dicho riesgo.

8) Una empresa envía publicidad a Ana y ella le comunica expresamente que no desea recibir más comunicaciones comerciales pero la empresa le responde que los datos fueron obtenidos legítimamente y que continuará enviándole publicidad. ¿Quién tiene razón?

La respuesta correcta es la descrita en la letra: B

Justificad vuestra respuesta (utilizad entre 50 y 200 palabras aproximadamente):

El derecho de oposición está regulado en el artículo 21 del RGPD y en el artículo 18 de la LOPDGDD. En el ámbito específico de la mercadotecnia, el artículo 21.2 del RGPD establece expresamente el derecho del interesado a oponerse en cualquier momento al tratamiento de sus datos personales con fines de mercadotecnia directa (marketing comercial).

La opción B es la correcta porque el ejercicio de este derecho en el contexto del marketing directo tiene carácter absoluto e incondicional. Una vez ejercida la oposición por parte de Ana, el artículo 21.3 del RGPD impone al responsable la obligación imperativa de dejar de tratar sus datos para dichos fines comerciales, prevaleciendo su voluntad sobre la legitimidad inicial de la obtención de los datos.

Las opciones A y C son incorrectas porque la legalidad de la recogida previa o la existencia de una relación contractual previa (como cliente) no limitan ni anulan el derecho del usuario a oponerse a envíos publicitarios posteriores. Por último, la opción D es incorrecta dado que no existen plazos legales predeterminados para oponerse o solicitar el cese de envíos comerciales, pudiendo ejercitarse en cualquier momento.

9) Una empresa española quiere enviar datos personales de algunos sus clientes a una entidad situada en un tercer país que no está incluido en una decisión de adecuación. La empresa pretende realizar la transferencia porque la ejecución del contrato comercial estipulado con sus clientes hace necesaria esta transferencia. ¿Cuál es la respuesta correcta?

La respuesta correcta es la descrita en la letra: A

Justificad vuestra respuesta (utilizad entre 50 y 200 palabras aproximadamente):

Las transferencias internacionales de datos a terceros países sin decisión de adecuación están reguladas en los artículos 44 y siguientes del RGPD. Con carácter general, el envío de datos requiere la articulación de garantías adecuadas (como las cláusulas contractuales tipo del artículo 46.2 del RGPD) o la concurrencia de alguna de las excepciones específicas contempladas en el artículo 49 del RGPD.

La opción A es la correcta porque, al carecer de una decisión de adecuación, la empresa no puede realizar la transferencia de forma ordinaria sin adoptar previamente una garantía legal exigida por la normativa. La simple invocación de la necesidad contractual entre el responsable y sus clientes debe interpretarse de forma restrictiva conforme a los criterios del Comité Europeo de Protección de Datos (CEPD), resultando insuficiente si no existe una garantía marco formal o no se cumple con el test de necesidad objetiva absoluta.

La opción B es incorrecta porque un pacto privado en el contrato comercial con el destinatario no suple las garantías legales impuestas por el RGPD. La opción C es incorrecta dado que las transferencias internacionales son totalmente lícitas cuando se cumplen las condiciones de los capítulos V del RGPD. Por último, la opción D es incorrecta porque la mera información posterior no legitima legalmente la transferencia.

10) Una empresa considera que, por tener menos de 50 trabajadores, puede utilizar las mismas medidas de seguridad para todos sus tratamientos, sin efectuar ninguna evaluación de riesgos. ¿Está en lo cierto?

La respuesta correcta es la descrita en la letra: B

Justificad vuestra respuesta (utilizad entre 50 y 200 palabras aproximadamente):

El principio de responsabilidad proactiva y la seguridad del tratamiento se contemplan en los artículos 24 y 32 del RGPD, así como en el artículo 28 de la LOPDGDD. La normativa exige que el responsable aplique medidas técnicas y organizativas apropiadas tras realizar un análisis de riesgos que valore la naturaleza, el alcance, el contexto y los fines del tratamiento, así como los riesgos para los derechos y libertades.

La opción B es la correcta porque el marco legal no establece exenciones basadas en el tamaño de la plantilla. La necesidad de evaluar los riesgos y adaptar las medidas de seguridad responde al nivel de riesgo inherente a las operaciones de tratamiento de datos que efectúa la entidad, no al número de empleados que tenga contratados.

Las opciones A, C y D son incorrectas dado que el número de trabajadores o la naturaleza privada de la empresa no otorgan ninguna exención general de realizar el análisis de riesgos ni justifican aplicar medidas de seguridad estándar de forma indiscriminada.

2ª PARTE. SUPUESTOS PRÁCTICOS

SUPUESTOS PRÁCTICO I (1 punto)

Laura solicita a una empresa que le indique qué datos personales conserva sobre ella, para qué los utiliza y a quién los comunica. La empresa responde que "la información es confidencial" y rechaza la solicitud.

1.- ¿Ha obrado la empresa correctamente?

Laura está ejerciendo su derecho de acceso, regulado de forma explícita en el artículo 15 del Reglamento General de Protección de Datos (RGPD) y en el artículo 13 de la Ley Orgánica 3/2018 (LOPDGDD). Este derecho faculta al titular de los datos a obtener del responsable del tratamiento la confirmación de si se están tratando o no sus datos personales y, en caso afirmativo, el acceso a los mismos, así como la información sobre los fines del tratamiento, las categorías de datos tratados y los destinatarios o categorías de destinatarios a los que se han comunicado o comunicarán. El argumento de la empresa aludiendo a que "la información es confidencial" carece de cualquier fundamento jurídico. El deber de confidencialidad y el secreto empresarial no pueden alegarse frente al propio titular de los datos para negarle el acceso a su información personal. Además, el artículo 12 del RGPD impone al responsable la obligación de facilitar el ejercicio de los derechos de los interesados y de responder sin dilación indebida y, a más tardar, en el plazo de un mes desde la recepción de la solicitud. Por tanto, la negativa injustificada de la empresa constituye una infracción del régimen de protección de datos, vulnerando el principio de transparencia y el derecho de acceso de la interesada.

2.- ¿Qué información puede solicitar Laura a esta empresa?

Laura tiene derecho a solicitar a la empresa una confirmación clara de si sus datos personales están siendo objeto de tratamiento y, en caso afirmativo, obtener una copia de dichos datos junto con una explicación detallada de la información prevista en el artículo 15.1 del RGPD y en la Guía del RGPD para Responsables del Tratamiento de la AEPD. En primer lugar, Laura puede exigir que se le informen los fines del tratamiento, es decir, las razones concretas por las que la entidad utiliza su información personal, así como las categorías de datos objeto de uso, ya sean datos identificativos, de contacto, financieros o de otra naturaleza. Asimismo, tiene derecho a conocer los destinatarios o categorías de destinatarios a los que se han comunicado o se prevé comunicar sus datos, identificando explícitamente a las terceras entidades que hayan tenido acceso a ellos. En segundo lugar, la empresa debe especificar el plazo previsto de conservación de sus datos personales o, en su defecto, los criterios fijados para determinar dicho periodo. Igualmente, Laura debe ser informada sobre el origen exacto de la información si esta no fue recabada directamente de ella, así como de la existencia de decisiones automatizadas o elaboración de perfiles, incluyendo la lógica aplicada y las consecuencias previstas de dichos tratamientos. Finalmente, la respuesta debe incluir la información sobre su facultad para solicitar la rectificación, supresión, limitación u oposición al tratamiento de sus datos, junto con la indicación expresa de su derecho a presentar una reclamación ante la Agencia Española de Protección de Datos (AEPD) en caso de disconformidad.

3.- ¿Puede la empresa cobrarle a Laura por dicha solicitud?

El artículo 12.5 del RGPD establece con carácter general el principio de gratuidad en el ejercicio de los derechos de los interesados (acceso, rectificación, supresión, oposición, etc.), principio recogido de forma idéntica en el artículo 12.1 de la LOPDGDD y en la Guía del RGPD para Responsables del Tratamiento publicada por la AEPD. Como única excepción, el propio artículo 12.5 del RGPD contempla que el responsable del tratamiento podrá cobrar un canon razonable basado en los costes administrativos o negarse a actuar únicamente cuando las solicitudes sean manifestamente infundadas o excesivas, especialmente debido a su carácter repetitivo. Corresponde al responsable del tratamiento la carga de probar el carácter manifestamente infundado o excesivo de la solicitud. Asimismo, el artículo 15.3 del RGPD señala que, si el interesado solicita copias adicionales de sus datos personales, la empresa sí podrá percibir por esas copias subsiguientes un canon razonable para cubrir los costes administrativos. No obstante, la primera copia y toda la información asociada a la solicitud inicial deben facilitarse siempre de forma totalmente gratuita.

4.- Una vez efectuada la solicitud, ¿Qué plazo tiene la empresa para responder?

El artículo 12.3 del RGPD y el artículo 12.4 de la LOPDGDD establecen que el responsable del tratamiento debe facilitar al interesado la información sobre las actuaciones realizadas en un plazo máximo de un mes a partir de la recepción de la solicitud de acceso. Asimismo, la normativa prevé que este plazo pueda prorrogarse otros dos meses si fuera necesario, teniendo en cuenta la complejidad y el número de solicitudes. Para que dicha prórroga sea válida,

la empresa debe informar a Laura de la ampliación del plazo y de los motivos de la dilación dentro del primer mes desde la recepción de su petición. Si la empresa decide no dar curso a la solicitud, el artículo 12.4 del RGPD exige que informe a Laura sin dilación, y a más tardar transcurrido un mes desde la recepción, de las razones de su no actuación y de la posibilidad de presentar una reclamación ante la Agencia Española de Protección de Datos (AEPD) o ejercitar acciones judiciales.

5.- ¿Puede la empresa denegar el acceso porque existan datos de terceros?

El artículo 15.4 del RGPD establece que el derecho a obtener copia de los datos no afectará negativamente a los derechos y libertades de terceros. Sin embargo, como precisan las Directrices 01/2022 del CEPD y la jurisprudencia de la AEPD, esto no justifica rechazar la solicitud en su totalidad. La empresa debe aplicar el principio de minimización y proceder a la anonimización o tachado de los datos del tercero (nombres, firmas, DNI, etc.) para entregar a Laura únicamente su información personal. Solo si es completamente imposible separar ambas informaciones y el acceso causa un perjuicio grave e inevitable al tercero, se podrá denegar el documento específico. En tal caso, la empresa debe motivar formalmente dicha decisión parcial conforme al artículo 12 del RGPD.

SUPUESTO PRÁCTICO II (1 punto)

EduPlay es una plataforma educativa para reforzar y dinamizar conocimientos de la ESO que se ofrece directamente a menores. Pablo, alumno cordobés de 13 años, se registra en la plataforma, proporcionando sus datos personales, para poder acceder a los contenidos. El sistema acepta automáticamente su consentimiento sin comprobar la intervención de sus padres.

1.- ¿Puede Pablo consentir por sí mismo el tratamiento?

No, Pablo no puede consentir por sí mismo el tratamiento de sus datos personales. El artículo 8.1 del Reglamento General de Protección de Datos (RGPD) fijó la edad mínima para prestar el consentimiento válido de manera directa por un menor entre los 13 y los 16 años, dejando la determinación exacta de este límite a la legislación nacional de cada Estado miembro. En el ordenamiento jurídico español, el artículo 7.1 de la Ley Orgánica 3/2018 (LOPDGDD) estableció de forma expresa que el tratamiento de los datos personales de un menor únicamente podrá basarse en su propio consentimiento cuando sea mayor de catorce años. Al tener Pablo 13 años, el consentimiento otorgado directamente por él es nulo de pleno derecho. Por tanto, conforme a lo dispuesto en el artículo 7.2 de la LOPDGDD y las directrices fijadas en la Guía del RGPD para Responsables del Tratamiento publicada por la AEPD, el tratamiento de los datos de un menor de catorce años solo será lícito si consta la autorización o el consentimiento de los titulares de la patria potestad o tutela.

2.- ¿Cómo debería operar Pablo para suscribirse a la plataforma?

Para que Pablo pueda suscribirse a la plataforma EduPlay, el procedimiento debe canalizarse a través de la representación legal de sus progenitores o tutores. Al tener 13 años, el artículo 7.2 de la LOPDGDD impide que el menor otorgue su consentimiento de forma autónoma (fijando el límite en los 14 años), por lo que el sistema de registro está obligado a solicitar previamente los datos de contacto de sus padres para recabar su autorización explícita. Asimismo, en virtud del artículo 8.2 del RGPD, EduPlay debe implementar mecanismos razonables de verificación para comprobar que el consentimiento ha sido prestado efectivamente por el titular de la patria potestad o tutela. La normativa y las directrices de las autoridades de control exigen que no se utilice una simple casilla de verificación, sino medios técnicos más robustos como la firma electrónica, la verificación mediante DNI o pasarelas de autenticación. Por último, conforme al artículo 12.1 del RGPD, EduPlay debe adaptar su deber de informar, ofreciendo los términos de uso y las políticas de privacidad en un lenguaje claro, sencillo y perfectamente accesible para el menor, garantizando al mismo tiempo la información completa y detallada para los tutores legales.

(Toda la fundamentación jurídica expuesta ha sido obtenida directamente de los recursos y bases de datos oficiales de la Biblioteca de la UOC, consultando de forma específica los buscadores de Jurisprudencia de la UE (EUR-Lex) para

el análisis del estándar europeo y el CENDOJO del Poder Judicial para verificar la doctrina jurisprudencial aplicable a la protección de datos de menores en España).

3.- ¿Puede la empresa limitarse a aceptar una declaración de Pablo indicando que tiene autorización de sus progenitoras/es?

El artículo 8.2 del RGPD establece expresamente que el responsable del tratamiento fará "esfuerzos razonables" para verificar que el consentimiento fue dado o autorizado por el titular de la patria potestad o tutela sobre el menor, teniendo en cuenta la tecnología disponible. Una simple declaración no verificada o marcar una casilla (checkbox) afirmando contar con permiso de los padres no constituye una verificación real ni diligente, ya que incumple el principio de responsabilidad proactiva (accountability) regulado en el artículo 5.2 del RGPD. Asimismo, la Agencia Española de Protección de Datos (AEPD) y la doctrina fijada por los tribunales españoles (disponible en CENDOJO) exigen la puesta en marcha de mecanismos de autenticación o comprobación efectiva (como la verificación por doble factor mediante correo/SMS enviado al adulto, el uso de firma electrónica o pasarelas de autenticación de identidad). Aceptar la sola palabra de un menor de 13 años viciaría la licitud del tratamiento conforme a los artículos 6 y 7 de la LOPDGDD.

4.- ¿Cómo debería redactarse la información dirigida a Pablo?

El artículo 12.1 del RGPD exige que toda información dirigida al público en general y, muy especialmente, la destinada de forma específica a un menor, se facilite en un formato claro, transparente, inteligible y de fácil acceso, utilizando un lenguaje sencillo. Este principio se ve reforzado por el Considerando 58 del propio Reglamento, el cual señala que los menores merecen una protección especial en materia de transparencia al ser menos conscientes de los riesgos y consecuencias del tratamiento de sus datos personales. Para cumplir con este requisito de transparencia adaptada, la plataforma EduPlay no debe utilizar jerga jurídica compleja ni términos técnicos opacos. La información debe presentarse mediante un enfoque de múltiples capas (layered privacy notice): una primera capa o resumen visual altamente intuitivo (con iconos, gráficos o un tono explicativo directo y cercano) que responda a preguntas básicas como "¿qué datos te pedimos?", "¿para qué los usamos?" y "¿quién nos da permiso?", enlazando a una segunda capa con la información legal completa destinada a sus representantes legales.

5.- ¿Cambiarías tus respuestas si Pablo tuviera 15 años?

Sí, las respuestas cambiarían sustancialmente en lo relativo a la validez del consentimiento y al procedimiento de suscripción. En primer lugar, la principal modificación afectaría a la legitimación para el tratamiento de los datos del menor. De acuerdo con el artículo 7.1 de la LOPDGDD, el tratamiento de los datos de un menor únicamente requiere la intervención de sus progenitores cuando este sea menor de catorce años. Al tener Pablo 15 años, supera dicho umbral legal, por lo que ostenta plena capacidad para prestar de manera autónoma y directa su propio consentimiento para registrarse en la plataforma EduPlay. Como consecuencia directa de lo anterior, la empresa ya no estaría obligada a recabar la autorización previa de sus progenitores o tutores legales ni a aplicar los mecanismos técnicos de verificación de la patria potestad exigidos por el artículo 8.2 del RGPD. La única excepción se daría en aquellos casos concretos en los que una ley de rango superior exija expresamente la intervención de los titulares de la patria potestad para la celebración de un contrato o acto jurídico determinado. Sin embargo, en lo respectivo al deber de transparencia, la respuesta se mantendría inalterada. Aunque Pablo tenga 15 años y pueda consentir por sí mismo, el artículo 12.1 del RGPD obliga a la empresa a redactar las cláusulas informativas en un lenguaje especialmente claro, accesible y sencillo, adaptado a su edad, al seguir manteniendo la condición de menor de edad sujeto a una especial protección normativa.

SUPUESTO PRÁCTICO III (1 punto)

La clínica dental Happyteeth contrata a la empresa tecnológica CloudData, S.L. para alojar su base de datos de pacientes. El contrato únicamente dice: "CloudData tendrá acceso a la información de los pacientes para prestar el servicio" pero no se especifica ni la duración, ni

las categorías de datos ni otras instrucciones o medidas de Seguridad que aplicaran a este contrato de servicios.

1.- ¿CloudData puede ser considerada encargada del tratamiento?

Desde el punto de vista jurídico, la empresa CloudData, S.L. debe ser considerada plenamente como encargada del tratamiento. De acuerdo con el artículo 4.8 del Reglamento General de Protección de Datos (RGPD), ostenta la condición de encargado del tratamiento toda persona física o jurídica que trate datos personales por cuenta de otra entidad que actúa como responsable. En este supuesto concreto, la clínica dental Happyteeth actúa como responsable del tratamiento conforme al artículo 4.7 del RGPD, puesto que es la entidad que determina las finalidades y la necesidad del uso de los datos de sus pacientes. Dado que CloudData, S.L. se limita a almacenar y alojar dicha base de datos en sus servidores con el único fin de prestar el servicio contratado, no decide sobre los usos ni el destino de la información, por lo que asume legalmente el rol de encargada del tratamiento.

2.- ¿Es suficiente el contrato existente o sus términos?

El contrato formalizado entre ambas partes es totalmente insuficiente y vulnera de forma directa las exigencias de la normativa europea y española de protección de datos. El artículo 28.3 del RGPD establece de forma imperativa que la relación entre un responsable y un encargado del tratamiento debe regularse mediante un contrato o acto jurídico que vincule expresamente a ambas partes. Este texto contractual debe delimitar de manera pormenorizada aspectos esenciales como el objeto, la duración, la naturaleza y la finalidad del tratamiento, así como el tipo de datos personales y las categorías de interesados. Asimismo, el contrato debe imponer la obligación explícita al encargado de tratar los datos siguiendo únicamente las instrucciones documentadas del responsable y adoptar formalmente las medidas de seguridad técnicas y organizativas exigidas por el artículo 32 del RGPD, elementos que en este caso han sido omitidos por completo.

3.- ¿Puede CloudData utilizar los datos para sus propios fines?

No, CloudData, S.L. no puede utilizar en ningún caso los datos personales de los pacientes para sus propios fines. Conforme al artículo 28.3.a) del Reglamento General de Protección de Datos (RGPD), el encargado del tratamiento está legalmente obligado a tratar los datos personales únicamente siguiendo las instrucciones documentadas del responsable del tratamiento. Si CloudData, S.L. decidiese utilizar la información almacenada para fines propios (como el análisis de mercado, la mejora de sus propios productos o el envío de comunicaciones comerciales), vulneraría la relación de encargo y pasaría a ser considerada automáticamente como responsable del tratamiento respecto de dicho tratamiento, asumiendo todas las responsabilidades y sanciones asociadas, según lo dispuesto en el artículo 28.10 del RGPD. Asimismo, la Ley Orgánica 3/2018, de Protección de Datos Personales y garantía de los derechos digitales (LOPDGDD), califica expresamente en su artículo 73.c) como infracción muy grave o grave la destinación de los datos a finalidades distintas de las indicadas por el responsable del tratamiento.

4.- ¿Necesita *CloudData* obtener el consentimiento de cada paciente para acceder a los datos?

No, CloudData, S.L. no necesita solicitar el consentimiento individual a los pacientes de la clínica para poder acceder y alojar sus datos. La legitimación para tratar los datos de los pacientes corresponde a la clínica dental Happyteeth como responsable del tratamiento (para los pacientes), en el marco de la prestación de los servicios sanitarios solicitados por los usuarios o el cumplimiento de obligaciones legales del sector sanitario. La intervención de CloudData, S.L. no constituye una cesión o comunicación de datos a un tercero que requiera el consentimiento de los interesados, sino un mero acceso a los datos por parte de un prestador de servicios en calidad de encargado del tratamiento. Por tanto, conforme al marco de protección de datos, basta con que el tratamiento principal por parte del responsable esté legitimado y que la relación de encargo se instrumente legalmente mediante el obligatorio contrato de encargo del tratamiento regulado en el artículo 28 del RGPD.

5.- ¿Qué debe hacer *CloudData* cuando finalice el Servicio prestado?

Cuando finalice la prestación del servicio de alojamiento, CloudData, S.L. tiene la obligación legal de suprimir o devolver al responsable todos los datos personales, así como de destruir cualquier copia existente de los mismos. De acuerdo con el artículo 28.3.g) del RGPD, el contrato entre ambas partes debe explicitar que, a elección del responsable del tratamiento (Happyteeth), el encargado deberá proceder a la devolución íntegra de la base de datos o a su supresión de forma segura e irreversible una vez concluida la relación de servicios. La única excepción autorizada por la normativa es que exista una norma del Derecho de la Unión Europea o del Derecho español que exija legalmente la conservación de dichos datos personales (por ejemplo, para atender posibles responsabilidades

derivadas del tratamiento durante los plazos de prescripción legales), en cuyo caso los datos deberán mantenerse bloqueados impidiendo cualquier otro tipo de uso.

SUPUESTO PRÁCTICO IV (1 punto)

Una empresa española contrata a un proveedor estadounidense de servicios de software de gestión de datos. El proveedor almacenará datos personales de clientes españoles. La empresa comprueba que el proveedor estadounidense está adherido al EU-U.S. Data Privacy Framework.

1.- ¿Este servicio contratado equivale a una transferencia internacional?

Sí, este servicio contratado constituye plenamente una transferencia internacional de datos. Según el Reglamento General de Protección de Datos (RGPD, Reglamento UE 2016/679), se produce una transferencia internacional cuando los datos personales son procesados, transmitidos o alojados en la infraestructura tecnológica de una entidad ubicada fuera del Espacio Económico Europeo (EEE), o cuando dicha entidad extranjera tiene acceso a ellos. En este caso, al tratarse de una empresa española que contrata a un proveedor con sede en Estados Unidos para almacenar y gestionar datos de clientes españoles en sus servidores, la operación encaja perfectamente en la definición de flujo transfronterizo de datos hacia un tercer país, independientemente de que el servicio se preste por vía telemática o de forma automatizada.

2.- ¿Podría utilizarse una decisión de adecuación para este servicio?

Sí, en este caso puede y debe utilizarse una decisión de adecuación como base legal para legitimar la transfer internacional de datos. Conforme al artículo 45 del RGPD, se autoriza la libre circulación de datos personales desde la U Europea hacia un tercer país sin necesidad de garantías adicionales ni autorizaciones previas cuando la Comisión Eur haya determinado mediante una decisión de adecuación que dicho país garantiza un nivel de protección adecuado. contexto de los flujos entre la UE y EE. UU., la Comisión Europea adoptó la decisión de adecuación sobre el EU-U.S. Privacy Framework (DPF) (Marco de Privacidad de Datos UE-EE. UU.). Por lo tanto, al haber verificado la empresa espa que el proveedor estadounidense se encuentra debidamente adherido y certificado de forma activa en la lista del DP transferencia internacional queda automáticamente amparada por dicha decisión de adecuación, garantizándos legalidad del tratamiento sin necesidad de recurrir a Cláusulas Contractuales Tipo (SCC) ni a Normas Corpora Vinculantes (BCR). (No obstante, la empresa española debe asegurarse de formalizar adicionalmente el correspond contrato de encargado del tratamiento previsto en el artículo 28 del RGPD).

3.- ¿Qué importancia tiene que el proveedor esté adherido al *EU-U.S. Data Privacy Framework*?

La adhesión y certificación activa del proveedor en el marco del EU-U.S. Data Privacy Framework (DPF) es de máxima importancia jurídica, ya que otorga una presunción legal de que la entidad estadounidense garantiza un nivel de protección de los datos personales sustancialmente equivalente al exigido dentro de la Unión Europea. Al estar certificado en la lista oficial del DPF, la Comisión Europea considera que dicho proveedor ofrece garantías suficientes, lo que permite a la empresa española transferir los datos personales de forma completamente legítima y ágil. Desde una perspectiva operativa y legal, esto simplifica significativamente el cumplimiento normativo para la empresa responsable, eximiéndola de la obligación de implementar salvaguardas complejas adicionales (como formalizar Cláusulas Contractuales Tipo) o de realizar una laboriosa Evaluación del Impacto de la Transferencia (Transfer Impact Assessment o TIA) previa a la contratación del servicio.

4.- ¿Qué ocurriría si el proveedor estadounidense no estuviese certificado en el *EU-U.S. Data Privacy Framework*?

Si el proveedor estadounidense no se encontrase certificado en el DPF, la transferencia internacional de datos no podría quedar amparada por la decisión de adecuación de la Comisión Europea, por lo que la empresa española estaría obligada a recurrir a otros instrumentos jurídicos previstos en el Reglamento General de Protección de Datos (RGPD) para poder realizar el envío de información. En concreto, la empresa debería implementar garantías adecuadas conforme al artículo 46 del RGPD, siendo lo habitual la firma de las Cláusulas Contractuales Tipo (Standard Contractual Clauses o SCC) aprobadas por la Comisión Europea, o la adopción de Normas Corporativas Vinculantes (Binding Corporate Rules o BCR) en el caso de grupos empresariales. Adicionalmente, conforme a la doctrina fijada tras la sentencia Schrems II del Tribunal de Justicia de la UE, la empresa tendría que realizar una

evaluación del impacto de la transferencia (TIA) para verificar si la legislación del país de destino permite al proveedor cumplir con el contenido de las cláusulas, debiendo adoptar medidas técnicas u organizativas adicionales (como un cifrado fuerte de extremo a extremo) si detecta riesgos de acceso indebido por autoridades del país receptor. Realizar la transferencia a un proveedor no certificado sin haber implementado ninguna de estas garantías alternativas supondría una infracción muy grave del RGPD, sancionable con multas de elevadísima cuantía por la Agencia Española de Protección de Datos (AEPD).

5.- ¿Una cláusula contractual permite automáticamente cualquier transferencia internacional?

No, la inclusión de una cláusula contractual en un contrato no permite de manera automática ni indiscriminada cualquier transferencia internacional de datos. Para que una cláusula de este tipo sea válida a efectos de legitimar la transferencia conforme al artículo 46.2.c) del RGPD, debe tratarse expresamente de las Cláusulas Contractuales Tipo (SCC)aprobadas oficialmente por la Comisión Europea, redactadas en los términos exactos estipulados por la normativa de la UE y sin modificaciones unilaterales que reduzcan la protección de los interesados. Además, la mera inclusión formal o firma de las SCC tampoco otorga una autorización automática absoluta si la legislación del país de destino de los datos (por ejemplo, normativas estatales sobre vigilancia masiva) interfiere de forma desproporcionada o impide la efectividad de las garantías pactadas en dicho contrato. Por consiguiente, la validez legal de las cláusulas contractuales depende de que estén complementadas con el análisis previo del nivel de protección del país de destino y de la implantación efectiva de las medidas de seguridad técnicas que garanticen que los datos estarán resguardados en todo momento.

SUPUESTO PRÁCTICO IV (2 puntos). ELABORACIÓN REPORTE BRECHA DE SEGURIDAD (2 puntos)

Una startup de servicios en la nube sufre un incidente de seguridad donde se filtran archivos de registros (logs) que contienen direcciones IP, correos y hashes de contraseñas de usuarios.

Como Delegada/o de Protección de Datos o integrante del equipo de seguridad de dicha startup, debes enviar una notificación de la brecha de seguridad a la Autoridad de Control. Indica, cuáles serán los elementos fundamentales que deben incluirse en esa comunicación, de conformidad con la normativa aplicable.

Puedes consultar, para ayudarte en esta tarea, los documentos informativos y las herramientas que la AEPD dispone en su página web: https://www.aepd.es/derechos-y-deberes/cumple-tus-deberes/medidas-de-cumplimiento/brechas-de-datos-personales-notificacion

SOLUCIÓN:

Como Delegada de Protección de Datos de la startup, la notificación formal de la brecha de seguridad para enviarla a la Agencia Española de Protección de Datos abarcaría los siguientes puntos:

1. Identificación del responsable del tratamiento y del Delegado de Protección de Datos

En el inicio del reporte debe constar la identificación completa de la startup en su condición de responsable del tratamiento (nombre comercial, denominación social, NIF, dirección postal y datos de contacto). Asimismo, resulta obligatorio incluir la identidad y los datos de contacto directos del Delegado de Protección de Datos (DPD) o del punto de contacto designado por el equipo de seguridad, a través de quien se podrá obtener más información detallada sobre el incidente.

2. Naturaleza y descripción detallada del incidente de seguridad

Se debe describir minuciosamente el origen y la tipología de la brecha acontecida (brecha de confidencialidad por filtración no autorizada de archivos de registros). En este apartado se explicitarán las categorías de datos personales afectados, indicando específicamente que el incidente ha comprometido direcciones IP, direcciones de correo electrónico y hashes de contraseñas de usuarios. Asimismo, se debe aportar una estimación aproximada del número total de afectados y del número de registros de datos personales potencialmente expuestos en los archivos de logs.

3. Descripción de las posibles consecuencias y riesgos del incidente

Es necesario incluir una evaluación fundada sobre los riesgos e impactos probables para los derechos y libertades de los usuarios afectados. En este supuesto práctico, se debe hacer constar que la exposición de correos y direcciones IP facilita ataques de suplantación de identidad (phishing) o rastreos, mientras que la filtración de los hashes de las contraseñas genera el riesgo de reutilización de claves en otros servicios (credential stuffing) si la solidez del algoritmo de cifrado resultase comprometida, pudiendo provocar accesos no autorizados a las cuentas de los clientes.

4. Medidas correctoras adoptadas o propuestas para mitigar el impacto

En la comunicación a la AEPD deben detallarse las actuaciones inmediatas de contención y respuesta técnica puestas en marcha por la startup para frenar el incidente y limitar sus efectos nocivos. Entre estas medidas se deben incluir el aislamiento o cierre del vector de fuga en el servidor de logs, el forzado preventivo de reseteo de contraseñas para los usuarios afectados, la invalidación de sesiones activas, el refuerzo de las políticas de cifrado/salteado (salting) de credenciales y el bloqueo de IPs sospechosas.

5. Cronología de los hechos y comunicación a los interesados

Se expondrá la línea temporal exacta del evento, indicando la fecha y hora en que ocurrió el incidente, la fecha de su detección por el equipo de seguridad y la fecha de comunicación a la Autoridad de Control, justificando el cumplimiento del plazo máximo de 72 horas previsto en el artículo 33.1 del RGPD. Finalmente, se indicará si el incidente entraña un alto riesgo que obligue a notificar directamente a los propios usuarios afectados (conforme al artículo 34 del RGPD) o, en su defecto, las pautas y recomendaciones de seguridad comunicadas a los clientes (como la recomendación urgente de cambiar la contraseña).

3ª PARTE. SUPUESTOS PRÁCTICOS. VERDADERO/FALSO

1) El interesado puede retirar su consentimiento en cualquier momento, aunque acabe de darlo

La afirmación es: VERDADERA

Justificad vuestra respuesta (utilizad entre 50 y 200 palabras aproximadamente):

La revocación del consentimiento está expresamente contemplada en el artículo 7.3 del RGPD y en el artículo 6.2 de la LOPDGDD. La normativa reconoce al interesado la facultad incondicional de retirar su consentimiento en cualquier momento, de forma tan fácil como lo prestó y sin necesidad de justificar su decisión, independientemente de que lo haya otorgado recientemente.

Esta libertad para revocar el consentimiento garantiza el control efectivo de la persona física sobre sus datos personales. No obstante, el propio precepto aclara que la retirada del consentimiento no afectará a la licitud del tratamiento basada en el consentimiento previo a su retirada.

Por tanto, cualquier cláusula o práctica que limite, condicione o imponga un plazo mínimo de permanencia antes de poder retirar el consentimiento resulta nula y contraria al marco legal europeo y español de protección de datos.

2) Los datos personales pueden conservarse indefinidamente mientras sigan almacenados de forma segura

La afirmación es: FALSO

Justificad vuestra respuesta (utilizad entre 50 y 200 palabras aproximadamente):

El artículo 5.1.e del RGPD y el artículo 8 de la LOPDGDD consagran el principio de limitación del plazo de conservación. Este principio establece que los datos personales solo deben mantenerse durante el tiempo estrictamente necesario para cumplir las finalidades para las que fueron recogidos.

La adopción de medidas de seguridad robustas o un almacenamiento seguro es un deber independiente (artículo 32 del RGPD) que no sustituye ni anula la obligación de limitar la conservación temporal de la información. Por lo tanto, disponer de un entorno altamente seguro no legitima el almacenamiento indefinido de los datos personales.

Una vez cumplida la finalidad y transcurridos los plazos legales de prescripción de responsabilidades que exigen su bloqueo (artículo 32 de la LOPDGDD), los datos deben destruirse o anónimizarse de forma irreversible, siendo contrario a Derecho conservarlos "por si acaso" de manera indefinida.

3) La pseudonimización hace que los datos dejen de estar sometidos al RGPD

La afirmación es: FALSA

Justificad vuestra respuesta (utilizad entre 50 y 200 palabras aproximadamente):

La pseudonimización se define en el artículo 4.5 del RGPD como el tratamiento de datos personales de manera que ya no puedan atribuirse a un interesado sin utilizar información adicional que se conserve por separado. El considerando 26 del RGPD aclara expresamente que los datos seudónimizados siguen siendo datos personales y, por lo tanto, quedan plenamente sometidos al ámbito de aplicación del RGPD.

La pseudonimización es una medida de seguridad y de protección desde el diseño (artículos 25 y 32 del RGPD) destinada a reducir los riesgos para los titulares, pero no desvincula la información de la normativa aplicable.

Solo la anonimización irreversible (aquella en la que resulta imposible reidentificar a la persona por cualquier medio razonable) exime a la información de la aplicación de las reglas de protección de datos. Mientras exista la posibilidad de revertir el proceso mediante información adicional, el régimen legal de garantías debe ser respetado íntegramente.

4) El derecho de oposición al marketing directo puede ejercerse, aunque el tratamiento inicialmente fuera lícito

La afirmación es: VERDADERA

Justificad vuestra respuesta (utilizad entre 50 y 200 palabras aproximadamente):

El derecho de oposición se regula en el artículo 21 del RGPD y en el artículo 18 de la LOPDGDD. En el ámbito específico del marketing directo, el artículo 21.2 del RGPD establece expresamente que el interesado tiene derecho a oponerse en todo momento al tratamiento de sus datos personales con dicha finalidad comercial.

El ejercicio de este derecho es absoluto e incondicional. Aunque la obtención originaria de los datos y su tratamiento inicial para el envío de publicidad hubieran sido totalmente lícitos (por ejemplo, basados en el consentimiento previo o en un interés legítimo), la manifestación de oposición por parte del titular invalida la continuidad de dicho tratamiento.

El artículo 21.3 del RGPD impone al responsable la obligación imperativa de dejar de tratar los datos personales para fines de mercadotecnia desde el momento en que se ejerza la oposición, prevaleciendo en todo caso la voluntad del interesado sobre la licitud previa de la recogida.

5) El principio de limitación de la finalidad impide cualquier tratamiento posterior para una finalidad distinta

La afirmación es: FALSA

Justificad vuestra respuesta (utilizad entre 50 y 200 palabras aproximadamente):

El principio de limitación de la finalidad se recoge en el artículo 5.1.b del RGPD, el cual establece que los datos personales serán recogidos con fines determinados, explícitos y legítimos, y no serán tratados posteriormente de manera incompatible con dichos fines.

No obstante, la norma no prohíbe de forma absoluta cualquier tratamiento posterior para una finalidad distinta, sino únicamente aquellos que resulten incompatibles. Además, el propio artículo 5.1.b especifica que el tratamiento posterior con fines de archivo en interés público, investigación científica o histórica o fines estadísticos no se considerará incompatible con los fines iniciales.

Asimismo, el artículo 6.4 del RGPD prevé la posibilidad de tratar datos para finalidades distintas cuando exista consentimiento del interesado, una norma del Derecho de la Unión o de los Estados miembros, o cuando se supere un juicio de compatibilidad analizando el vínculo entre finalidades, el contexto de la recogida y las garantías adoptadas.

6) El encargado debe seguir siempre las instrucciones documentadas del responsable

La afirmación es: VERDADERA

Justificad vuestra respuesta (utilizad entre 50 y 200 palabras aproximadamente):

El régimen jurídico del encargado del tratamiento se encuentra regulado en el artículo 28 del RGPD y el artículo 33 de la LOPDGDD. La normativa establece con carácter imperativo que la actuación del encargado debe quedar vinculada por un contrato u otro acto jurídico formal que le obligue a tratar los datos personales únicamente siguiendo las instrucciones documentadas del responsable del tratamiento.

La afirmación es verdadera porque el artículo 28.3.a del RGPD impone este deber de subordinación operacional de manera estricta, incluyendo expresamente lo relativo a las transferencias internacionales de datos. El encargado actúa por cuenta y bajo la autoridad del responsable, por lo que carece de autonomía para decidir las finalidades o los medios del tratamiento.

La única matización legal que contempla el propio artículo 28.3.a es la existencia de una obligación legal derivada del Derecho de la Unión o del Estado miembro aplicable al encargado, en cuyo caso este deberá informar al responsable antes del tratamiento, salvo que la ley lo prohíba por razones de interés público. En todo lo demás, la obediencia a las instrucciones documentadas es absoluta.

7) Una violación de seguridad debe notificarse siempre a la autoridad de control, aunque no genere riesgos para las personas

La afirmación es: FALSA

Justificad vuestra respuesta (utilizad entre 50 y 200 palabras aproximadamente):

La notificación de brechas de seguridad a la autoridad de control está regulada en el artículo 33.1 del RGPD. Este precepto establece explícitamente que el responsable del tratamiento debe notificar la violación de la seguridad a la autoridad competente a menos que sea improbable que dicha violación constituya un riesgo para los derechos y las libertades de las personas físicas.

Por tanto, la obligación de notificar no opera de forma universal e incondicional ante cualquier incidente de seguridad. Cuando la entidad realiza un análisis previo y determina de manera razonada que la brecha carece de riesgo para los interesados (por ejemplo, al tratarse de datos cifrados de forma intangible o incidentes menores sin impacto reputacional ni material), no se exige la notificación formal a la autoridad de control.

No obstante, el responsable mantiene el deber de documentar internamente cualquier violación de seguridad según el artículo 33.5 del RGPD, incluyendo los hechos, sus efectos y las medidas adoptadas, para acreditar la adecuación de su actuación ante un eventual requerimiento.

8) Todas las organizaciones están obligadas a designar un delegado de protección de datos

La afirmación es: FALSA

Justificad vuestra respuesta (utilizad entre 50 y 200 palabras aproximadamente):

La designación obligatoria del Delegado de Protección de Datos (DPD) se regula en el artículo 37.1 del RGPD y se concreta en el ámbito nacional en el artículo 34.1 de la LOPDGDD. La normativa no impone esta figura a todas las organizaciones de manera generalizada, sino únicamente en supuestos legalmente tasados.

Conforme al artículo 37.1 del RGPD, el nombramiento de un DPD solo es obligatorio en tres casos: cuando el tratamiento lo realice una autoridad u organismo público, cuando las actividades principales requieran una observación habitual y sistemática de interesados a gran escala, o cuando consistan en el tratamiento a gran escala de categorías especiales de datos o datos relativos a condenas penales. Por su parte, la LOPDGDD detalla un listado cerrado de sectores e instituciones obligadas (como centros docentes, entidades financieras o aseguradoras).

Para el resto de organizaciones privadas o profesionales que no cumplan con estos criterios cuantitativos o cualitativos, la designación de un DPD es voluntaria (artículo 37.4 del RGPD), aunque recomendable para garantizar el cumplimiento normativo.

9) Una fotografía puede ser, además de un dato personal, un dato biométrico

La afirmación es: VERDADERA

Justificad vuestra respuesta (utilizad entre 50 y 200 palabras aproximadamente):

El artículo 4.14 del RGPD define los datos biométricos como aquellos obtenidos a partir de un tratamiento técnico específico, relativos a las características físicas, fisiológicas o conductuales de una persona física que permitan o confirmen su identificación única, como las imágenes faciales.

Cualquier fotografía que permita identificar a una persona constituye, por definición, un dato personal genérico (artículo 4.1 del RGPD). Sin embargo, el considerando 51 del RGPD aclara que las fotografías no deben considerarse sistemáticamente datos biométricos, sino solo cuando sean objeto de un tratamiento técnico específico que permita la identificación o la autenticación unívoca del individuo (como en sistemas de reconocimiento facial).

Por tanto, una imagen fotográfica siempre es un dato personal, pero alcanzará adicionalmente la condición jurídica de dato biométrico (y de categoría especial de datos conforme al artículo 9 del RGPD) en aquellos supuestos en los

que se apliquen medios técnicos informáticos destinados a la extracción de patrones biométricos para la identificación unívoca del sujeto. Nota: Es importante resaltar el "puede ser" para la veracidad de la afirmación.

10) El ejercicio del derecho de supresión obliga a eliminar los datos en todo caso

La afirmación es: FALSA

Justificad vuestra respuesta (utilizad entre 50 y 200 palabras aproximadamente):

El derecho de supresión (o derecho al olvido) está regulado en el artículo 17 del RGPD y el artículo 15 de la LOPDGDD. La normativa no establece un derecho absoluto que obligue a la eliminación incondicional e inmediata de los datos en todos los supuestos.

El propio artículo 17.3 del RGPD contempla excepciones tasadas en las que no procede la supresión. Entre ellas destacan el cumplimiento de una obligación legal que exija el tratamiento, razones de interés público en el ámbito de la salud, fines de archivo en interés público o investigación, y la formulación, el ejercicio o la defensa de reclamaciones.

Asimismo, cuando resulta procedente estimar la supresión, el artículo 32 de la LOPDGDD dispone que los datos no deben destruirse de forma inmediata si deben mantenerse bloqueados para atender posibles responsabilidades derivadas del tratamiento durante sus plazos de prescripción. Por tanto, el ejercicio del derecho no implica la eliminación automática e ilimitada de la información.